Report - Esercizio Password Cracking

W14D1 - Pratica | Cybersecurity & Ethical Hacking | Epicode

Studente:	Giovanni Pio Cerasoli
Corso:	Cybersecurity & Ethical Hacking
Modulo:	Week 14 - D1 - Attacchi ai sistemi
Traccia:	Password cracking
Data:	**13/10/2026**

1. SQL Injection - Estrazione degli hash

Di seguito lo screenshot della SQL injection eseguita su DVWA per estrarre username e password (hash) dalla tabella *users* del database, tramite tecnica UNION-based.

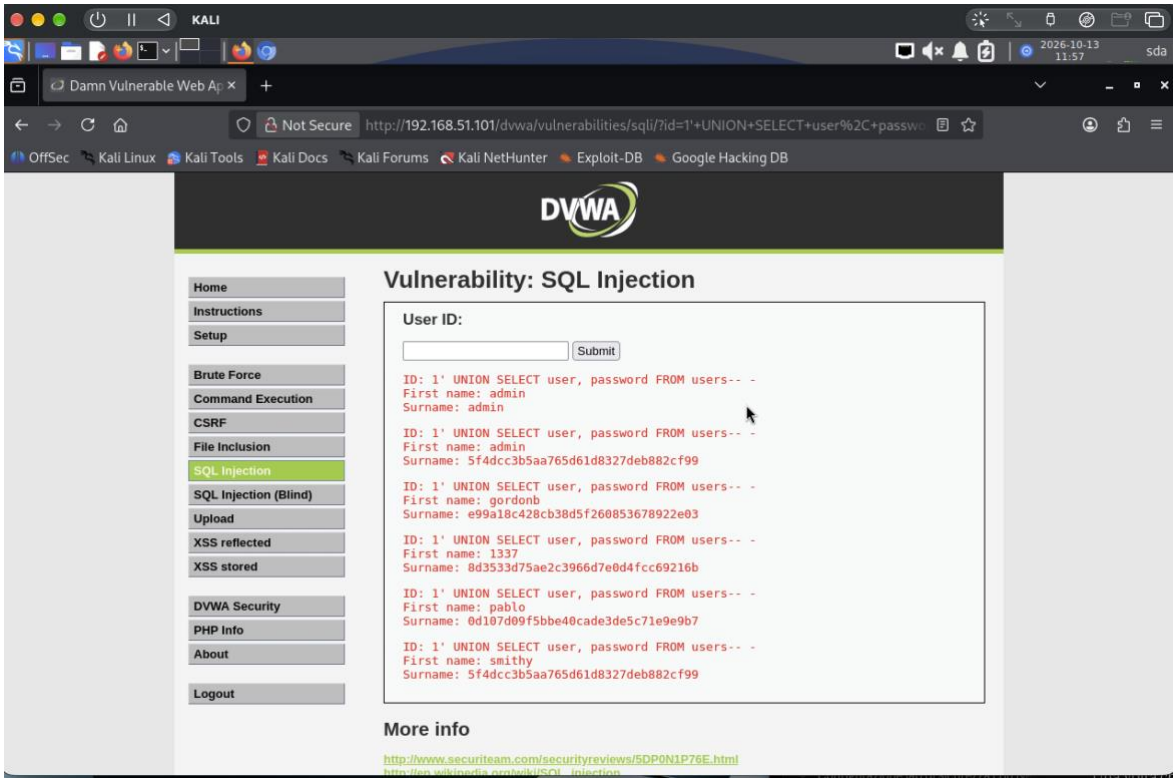


Figura 1 - Estrazione hash tramite SQL injection (UNION SELECT user, password FROM users)

2. Tipologia e meccanismo del cracking

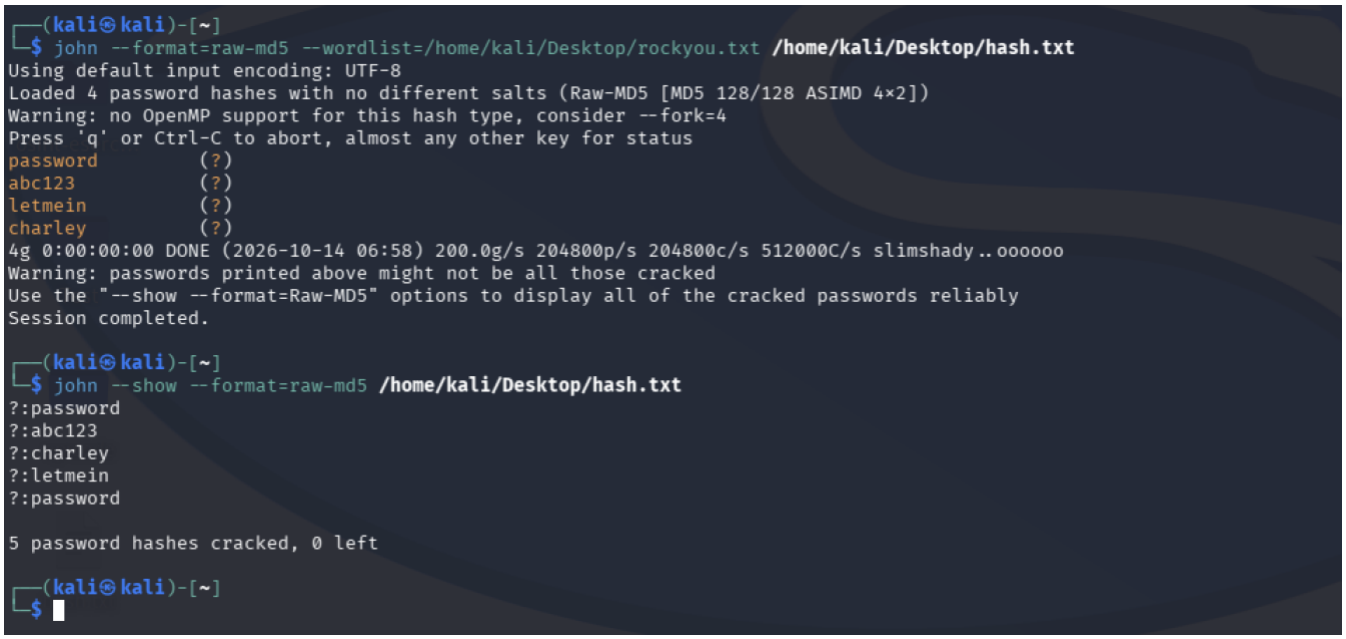
Gli hash estratti sono nel formato **MD5**, una funzione di hashing crittografico one-way: a differenza della cifratura, non è possibile invertirla matematicamente per risalire alla password originale. L'unico modo per recuperare la password in chiaro è quindi il **cracking offline**, cioè generare password candidate, calcolarne l'hash MD5 e confrontarlo con l'hash target fino a trovare una corrispondenza.

Per il cracking è stato utilizzato **John the Ripper**, in modalità **dictionary attack**: lo strumento calcola l'hash MD5 di ogni parola contenuta in una wordlist (nello specifico *rockyou.txt*, una lista contenente milioni di password reali trapelate da data breach) e lo confronta con gli hash da craccare. In caso di corrispondenza, la password in chiaro viene mostrata.

Comando utilizzato:

```
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

L'algoritmo MD5 risulta particolarmente vulnerabile a questo tipo di attacco per due motivi principali: è un algoritmo progettato per essere **veloce** da calcolare (ottimo per l'uso originario, pessimo dal punto di vista della sicurezza delle password), e in questo caso non viene utilizzato alcun **salt**, rendendo gli hash vulnerabili anche ad attacchi tramite rainbow table, oltre che a dictionary e brute-force attack.



3. Esecuzione del cracking e risultato

Figura 2 - Esecuzione del cracking con John the Ripper

Tabella riassuntiva dei risultati

Username	Hash MD5	Password trovata
admin	5f4dcc3b5aa765d61d8327deb882cf99	password
gordonb	e99a18c428cb38d5f260853678922e03	abc123
1337	8d3533d75ae2c3966d7e0d4fcc69216b	charley
pablo	0d107d09f5bbe40cade3de5c71e9e9b7	letmein

smithy	5f4dcc3b5aa765d61d8327deb882cf99	password